ZCAS University

MASTER OF SCIENCE IN COMPUTER SCIENCE/MASTER OF SCIENCE IN INFORMATION TECHNOLOGY/MASTER OF SCIENCE IN CYBERSECURITY/MASTER OF SCIENCE IN DATA SCIENCE

CIT5342 - SECURITY MANAGEMENT

FINAL EXAMINATION

28TH NOVEMBER 2024

14:00 – 17:00 HOURS

TIME ALLOWED: READING AND WRITING TIME – THREE HOURS AND FIVE MINUTES

INSTRUCTIONS:

1. Section A: **Question One** in Section A is **compulsory**.
2. Sections B: Answer **TWO** Questions from this section.
3. This examination paper carries a total of **100 marks**.
4. Do Not Open the paper Until told to do so by the Invigilator.

SECTION A – COMPULSORY

QUESTION ONE

(a) DES and SDES are both symmetric-key block ciphers, with DES being a widely used encryption standard in the past and SDES being a simplified variant primarily used for educational purposes. Both algorithms use a similar structure but differ in terms of block size and key size.

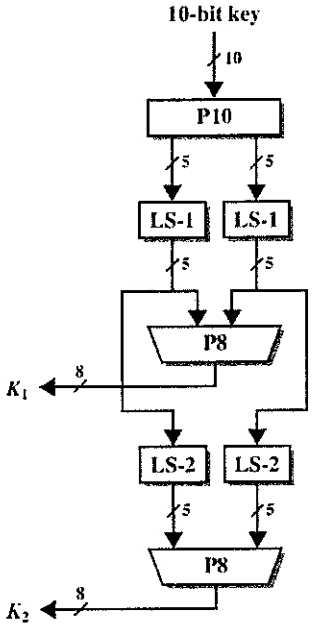
Given that S-DES is in use and the permutations, consider the exhibits below and answer the questions that follow:

P10

```
Input : 1 2 3 4 5 6 7 8 9 10
Output: 3 5 2 7 4 10 1 9 8 6
```

P8

```
Input : 1 2 3 4 5 6 7 8 9 10
Output: 6 3 7 4 8 5 10 9
```



Generate the two round keys for the private key 1010011011. **[10 Marks]**

(b) Given the following S-boxes, find the resultant concatenated stream of bits for an input stream of 11010111 in S-DES implementation.

$$S0 = \begin{bmatrix} 01 & 00 & 11 & 10 \\ 11 & 10 & 01 & 00 \\ 00 & 10 & 01 & 11 \\ 11 & 01 & 11 & 10 \end{bmatrix} \quad S1 = \begin{bmatrix} 00 & 01 & 10 & 11 \\ 10 & 00 & 01 & 11 \\ 11 & 00 & 01 & 00 \\ 10 & 01 & 00 & 11 \end{bmatrix}$$

[5 Marks]

(c) Given two prime values, p=7 and q=13, generate two asymmetric encryption keys (K_p and K_s) based on the RSA algorithm. **[10 Marks]**

(d) Your organization has deployed a new web application, and during a penetration test using Metasploit, a vulnerability linked to CVE-2023-12345 is identified. The vulnerability allows unauthorized remote code execution. Using this scenario, answer the following questions:

i. Briefly explain the purpose of the Metasploit framework and describe how it can be used to identify and exploit vulnerabilities such as the one found. **[5 Marks]**

ii. Define what a CVE is and explain its importance in managing vulnerabilities. Use CVE-2023-12345 as an example in your explanation. **[5 Marks]**

iii. Based on the identified vulnerability, discuss the potential threat, vulnerability, risk, and impact to the organization if this issue is exploited. **[10 Marks]**

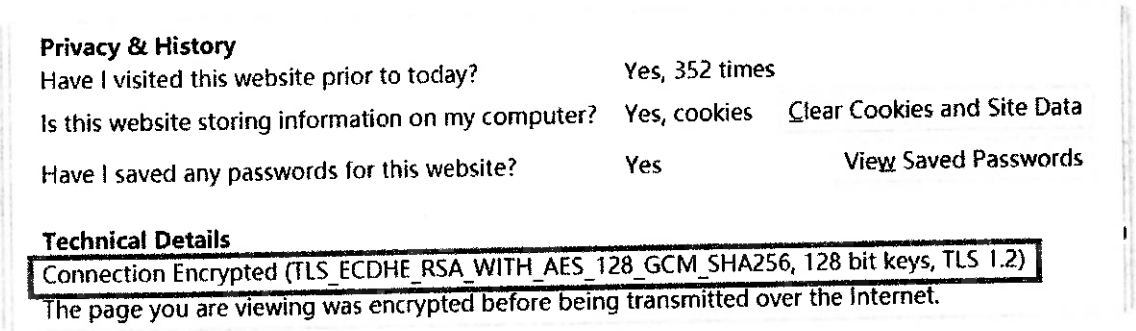
iv. Suggest immediate steps the organization should take to remediate the vulnerability and prevent exploitation. **[5 Marks]**

(Total 50 marks)

SECTION B: Answer ANY TWO Questions in this section.

QUESTION TWO

The screenshot provided shows information about a secure connection used by a website. Analyze the details and answer the following questions:



a) Explain the significance of the encryption protocol **TLS 1.2** in ensuring secure communication over the internet and compare it briefly to other versions of TLS. **[5 Marks]**

b) Break down and describe the meaning of each component in the cipher suite: **`TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256`.** Explain their roles in securing the connection. **[10 Marks]**

c) Discuss the importance of **128-bit encryption** for data security and compare it with 256-bit encryption. Under what scenarios is 128-bit encryption sufficient, and when might 256-bit be preferable? **[5 Marks]**

d) Evaluate how cookies, stored passwords, and website visit history (as shown in the screenshot) can pose security risks, even when TLS encryption is used. Provide mitigation strategies for each. **[5 Marks]**

(Total 25 Marks)

QUESTION THREE

Risk management is a key aspect of information security. Using your understanding of the NSTISSC Security Model (McCumber Cube), the risk matrix, and risk treatment strategies, answer the following questions:

a) Explain the three dimensions of the McCumber Cube and discuss how it provides a comprehensive framework for information security management. Provide an example to illustrate its application. **[10 Marks]**

b) Define the risk matrix and explain how it is used to assess and prioritize risks. Provide a scenario and demonstrate how a risk can be mapped onto a risk matrix. **[7 Marks]**

c) Describe the four main approaches to risk treatment (avoidance, mitigation, transfer, and acceptance). For each approach, provide a practical example in the context of managing information security risks. **[8 Marks]**

(Total 25 Marks)

QUESTION FOUR

Understanding attack types, threats, vulnerabilities, and malware is essential in information security. Answer the following questions:

a) Differentiate between a threat and a vulnerability. Using a practical example, explain how a threat can exploit a vulnerability to compromise a system. **[5 Marks]**

b) Describe the following types of attacks and provide an example for each:

- Phishing
- Distributed Denial of Service (DDoS)
- SQL Injection
- Man-in-the-Middle (MITM)
- XSS

[10 Marks]

c) Define malware and explain the characteristics of the following types:

- Virus
- Ransomware
- Trojan
- Spyware

[10 Marks]

(Total 25 marks)

END OF EXAMINATION.